Token & secret matrix

v1.0.0-docs.1
target template v1.0.0

> Least-privilege tokens and secrets by job. Full model: REFERENCE §14 · ACTIONS CATALOG §4.

WHO NEEDS WHAT

NEED	TOKEN/SOURCE	SCOPE	STORED AS
Repo CI, dependency review	`GITHUB_TOKEN`	`contents: read`	Automatic, per-run
Tracker audit (advisory)	`TRACKER_TOKEN` or GitHub App	Project read	Repo secret; skip cleanly if unset
Tracker audit (release gate)	Same	Project read	`release` environment secret
Release publish (generic)	`GITHUB_TOKEN`	`contents: write` (publish job only)	Automatic
Container publish	`GITHUB_TOKEN`	`packages: write`	Automatic
Package/cloud publish	OIDC or env secret	Minimal publish role	`release` environment
Signing/notarization	Apple cert + app password	n/a	`release` environment secrets

`TRACKER_TOKEN` name is configurable via `tracker.config.json` → `workflows.audit.tokenSecret`. Never hard-code another name in docs or workflow callers.

RULES

- Start with `permissions: {}` and grant the minimum per job; publish jobs only on a tag or explicit dispatch.
- Fork/untrusted PRs get **no secrets** and a read-only token. Never use `pull_request_target` with untrusted checked-out code.
- Audit is read-only: project read is enough; no write scopes needed.
- Prefer OIDC/short-lived credentials over long-lived cloud keys; document any static exception.
- Never put tokens in repo, config, issues, comments, logs, artifacts, or caches. Mask derived values; rotate PATs and certs.
- Publishing/signing runs inside the protected `release` environment with required reviewers; PR jobs never declare it.
- OIDC jobs get `id-token: write` only on the publish job; cloud trust policies pin repo + tag/environment.
- Environment deployment rules allow tags `v*` only; secrets are scoped to that environment, not repo-wide.

SAFE CI PERMISSION SHAPE

```
permissions: {}          # workflow default: deny
jobs:
  ci:
    permissions:
      contents: read     # only what the job proves it needs
```

SETUP CHECKLIST

- □ Audit token created project-scoped (PAT or App) and stored as a secret.
- □ `workflows.audit.tokenSecret` matches the stored name.
- □ Release environment created with reviewers; tag rules restrict `v*`.
- □ Signing/publish secrets are environment secrets, absent-safe, and documented.
- □ CI needs no secrets; local parity commands run without credentials.

Links: CI/security token matrix · UPGRADING · SECURITY.md